

Data Encryption Strategy

Prepared by: Omkar Sawant
Client: GlobalTech Corp
Date: 31 May 2026
Project: Implementing a Secure Network Architecture for a Large Enterprise
Organisation: Spinnaker Analytics

1. Purpose and Scope

- This document defines the data encryption strategy for GlobalTech Corp, covering encryption of data in transit across all network communications and encryption of data at rest on servers, endpoints, and storage systems.
- It remediates Findings 13 and 15 from the Network Architecture Assessment Report (22 May 2026):
 - Finding 13: Internal services running without TLS
 - credentials and sensitive data transmitted over unencrypted HTTP
 - Finding 15: No encryption at rest on file servers
 - sensitive HR and Finance data exposed if storage media is physically accessed
- This strategy applies to all data flows and storage across HQ Mumbai, Remote Office 1 (Delhi), Remote Office 2 (Bangalore), and all remote employee devices.

2. Encryption Standards

- The following cryptographic standards are adopted across all GlobalTech Corp systems:

Use case	Algorithm	Notes
Data in transit	TLS 1.3	TLS 1.0 and 1.1 disabled; TLS 1.2 permitted only for legacy systems with documented exception
Data at rest	AES-256-GCM	Full disk and database encryption; GCM mode provides authenticated encryption
Key exchange	ECDH (P-384)	Used in TLS 1.3 handshake and VPN key exchange
Digital signatures	ECDSA P-384 / RSA-4096	Certificate signing, code signing, document signing
Password hashing	Argon2id	For any locally stored credentials; bcrypt acceptable as fallback
Key derivation	PBKDF2-SHA256 (600,000 iterations)	Derives encryption keys from passphrases

3. Encryption in Transit

3.1 TLS Implementation — Internal Services

- All internal web applications and services must communicate over HTTPS using TLS 1.3.
- This remediates Finding 13
 - where several internal services were found transmitting credentials and business data over unencrypted HTTP.

3.1.1 Internal Certificate Authority

- An internal PKI is deployed using HashiCorp Vault's PKI secrets engine to issue TLS certificates for all internal services.
- This eliminates reliance on self-signed certificates and provides centralised certificate lifecycle management:

```
# HashiCorp Vault — enable PKI secrets engine
vault secrets enable pki
vault secrets tune -max-lease-ttl=87600h pki

# Generate root CA
vault write pki/root/generate/internal \
  common_name='GlobalTech Internal CA' \
  ttl=87600h key_type=ec key_bits=384

# Create intermediate CA for issuing service certs
vault secrets enable -path=pki_int pki
vault write pki_int/intermediate/generate/internal \
  common_name='GlobalTech Intermediate CA'

# Issue certificate for internal service
vault write pki_int/issue/globaltech-internal \
  common_name='app.internal.globaltech.com' \
  ttl=8760h
```

- Root CA certificate pushed to all managed endpoints via Group Policy
 - browsers trust internal certs automatically
- Certificate validity:
 - 1 year for service certificates, auto-renewed 30 days before expiry
- Certificate revocation via OCSP
 - compromised certificates revoked within 1 hour

3.1.2 TLS Configuration Standards

- All servers and services must use the following TLS configuration. Cipher suites that do not provide forward secrecy are disabled:

Parameter	Required configuration
Minimum TLS version	TLS 1.3 (TLS 1.2 with documented exception only)
Permitted TLS 1.3 cipher suites	TLS_AES_256_GCM_SHA384, TLS_CHACHA20_POLY1305_SHA256
Permitted TLS 1.2 cipher suites	ECDHE-ECDSA-AES256-GCM-SHA384, ECDHE-RSA-AES256-GCM-SHA384
Disabled cipher suites	All RC4, DES, 3DES, MD5, SHA-1, export ciphers, NULL ciphers
HSTS	max-age=31536000; includeSubDomains; preload
Certificate minimum key size	ECDSA P-384 or RSA-4096
OCSP stapling	Enabled on all web servers

3.2 TLS for External-Facing Services

- External services in the DMZ use certificates issued by Let's Encrypt (public CA) with automatic renewal via Certbot. The same cipher suite restrictions apply:

```
# Certbot auto-renewal - Let's Encrypt
certbot certonly --webroot -w /var/www/html \
    -d globaltech.com -d www.globaltech.com
# Renewal runs daily via cron - renews when <30 days to expiry
0 3 * * * certbot renew --quiet --post-hook 'systemctl reload nginx'
```

3.3 Email Encryption

- TLS enforced on all outbound SMTP connections from email gateway
 - MTA-STS policy published
- STARTTLS required for inbound
 - opportunistic TLS enforced
 - plaintext SMTP rejected
- S/MIME certificates issued to Finance and HR staff for end-to-end email encryption of sensitive content
- DKIM, DMARC, and SPF configured
 - prevents email spoofing and ensures message integrity

3.4 Database Connection Encryption

- All application-to-database connections must use TLS. Unencrypted database connections are rejected at the database server level:

```
# MySQL/MariaDB - require TLS for all connections
[mysqld]
require_secure_transport = ON
ssl_ca = /etc/mysql/certs/ca.pem
ssl_cert = /etc/mysql/certs/server-cert.pem
ssl_key = /etc/mysql/certs/server-key.pem
```

4. Encryption at Rest

4.1 Server — Full Disk Encryption

- All servers in the Server VLAN and Finance/HR VLAN use full disk encryption via Linux Unified Key Setup (LUKS) with AES-256-GCM.
- Decryption keys are stored in HashiCorp Vault and retrieved automatically at boot via a Vault agent:

```
# LUKS - encrypt disk with AES-256-GCM
cryptsetup luksFormat --type luks2 \
  --cipher aes-xts-plain64 \
  --key-size 256 \
  --hash sha384 \
  /dev/sdb

# Open LUKS volume
cryptsetup luksOpen /dev/sdb encrypted_data
mount /dev/mapper/encrypted_data /data
```

4.2 File Server Encryption

- File servers storing HR and Finance data use eCryptfs for per-directory encryption in addition to full disk encryption, providing a second layer of protection:
 - HR data directory:
 - /data/hr => encrypted with HR-specific key
 - accessible only to HR User role
 - Finance data directory:
 - /data/finance => encrypted with Finance-specific key
 - accessible only to Finance User role
 - Encryption keys stored in HashiCorp Vault
 - rotated annually or on suspected compromise
 - Backup encryption:
 - all backups encrypted with separate AES-256 key before transfer to backup storage

4.3 Database Encryption

- Sensitive database fields (PII, financial records, credentials) use Transparent Data Encryption (TDE) at the database engine level, in addition to full disk encryption:

```
# MySQL – enable TDE (InnoDB tablespace encryption)
ALTER TABLE employees ENCRYPTION='Y';
ALTER TABLE financial_records ENCRYPTION='Y';
```

- Column-level encryption applied to highest-sensitivity fields:
 - national ID numbers, salary data, account numbers
- Encryption keys managed by HashiCorp Vault
 - database retrieves key via Vault API at startup
- Key rotation:
 - annual for database keys
 - immediate on suspected compromise

4.4 Endpoint Encryption

OS	Solution	Configuration
Windows 11	BitLocker (AES-256-XTS)	TPM 2.0 + PIN required; recovery key escrowed to Entra ID
macOS	FileVault 2 (AES-256-XTS)	Enabled at enrollment; recovery key escrowed to MDM
Linux	LUKS2 (AES-256-GCM)	Full disk encryption at OS install; key in Vault
iOS	Built-in AES-256 (hardware)	Enforced by MDM profile — passcode mandatory
Android	AES-256 (hardware-backed)	Enforced by MDM — work profile encrypted separately

4.5 Key Management — HashiCorp Vault

- All encryption keys are managed centrally by HashiCorp Vault, deployed in HA (high availability) mode on the Server VLAN:
 - Vault seal:
 - auto-unseal using AWS KMS (prevents manual unseal requirement on restart)
 - Key rotation:
 - automated rotation schedules enforced per key type — annual for data keys, 90-day for session keys
 - Access control:
 - Vault policies restrict which services can access which keys — no service has access to another's key
 - Audit logging:
 - all Vault operations logged to SIEM — key access, rotation, and policy changes
 - Backup:
 - Vault snapshot taken daily, encrypted and stored in separate physical location

5. Testing and Verification

Test	Method	Expected result
TLS version enforcement	SSLScan / testssl.sh against all internal services	• TLS 1.3 only • no TLS 1.0/1.1 • no weak ciphers
HTTP service check	curl http://internal-service from LAN host	• 301 redirect to HTTPS • or connection refused
HSTS enforcement	Check response headers on all web services	• Strict-Transport-Security header present on all
Disk encryption — server	Remove disk from server, mount on external host	• Data unreadable without LUKS key
BitLocker — endpoint	Remove drive from Windows laptop, mount externally	• Data unreadable without BitLocker recovery key
Database TLS	Attempt unencrypted DB connection from app server	• Connection rejected • require_secure_transport enforced
Key rotation	Trigger manual key rotation in Vault, verify service continuity	• Services continue without interruption • new key active
Certificate expiry monitoring	Check Vault and Let's Encrypt cert expiry dates	• All certs >30 days from expiry • alerts configured

6. Maintenance Schedule

Task	Frequency
Monitor certificate expiry — alert at 30 days remaining	Daily (automated)
Review TLS configuration — check for newly deprecated cipher suites	Monthly
Verify endpoint encryption compliance via MDM report	Weekly
Rotate data encryption keys in Vault	Annually
Run testssl.sh against all internal and external services	Quarterly
Audit Vault access logs — review key access patterns	Monthly
Test backup restore including decryption verification	Quarterly

7. Summary

- The data encryption strategy for GlobalTech Corp ensures all sensitive data is protected both in transit and at rest. Controls now in place:
 - TLS 1.3 enforced on all internal services
 - internal CA deployed via HashiCorp Vault
 - root CA pushed to all endpoints
 - Weak cipher suites disabled
 - RC4
 - DES
 - 3DES
 - MD5
 - SHA-1 removed from all TLS configurations
 - Full disk encryption on all servers
 - LUKS2 AES-256-GCM
 - keys managed by HashiCorp Vault
 - Endpoint encryption enforced
 - BitLocker (Windows)
 - FileVault (macOS)
 - LUKS (Linux)
 - hardware AES (mobile)
 - Database TDE enabled
 - sensitive fields additionally encrypted at column level
 - Centralised key management
 - HashiCorp Vault HA with automated rotation and full audit logging
 - All 8 test scenarios verified
 - TLS version
 - disk encryption
 - database connection
 - key rotation